

Triage assistant. Not a replacement for human review. Do not auto-close findings based on this output alone.

> About

TriageGPT — LLM-Assisted SAST Triage

Upload a Semgrep `--json` output, pick a model and prompt variant, and the app classifies every finding as **true_positive**, **false_positive**, or **needs_review** with a confidence score and reasoning. Each finding is reviewed independently; verdicts are model output and must be checked by a human.

Semgrep JSON output

 semgre...ceshop.json 47.4KB

+

Model

gemini

Prompt variant

baseline

Run triage

Done — 26 findings triaged.

Results

26 findings · model: `gemini` · variant: `baseline`

	rule	file:line	verdict	confidence	reasoning
2	hardcoded-hmac-key	lib/insecurity.ts:44	true_positive	1.00	The Semg
3	hardcoded-jwt-secret	lib/insecurity.ts:56	needs_review	0.90	The Semg
4	hardcoded-hmac-key	lib/insecurity.ts:152	needs_review	0.80	The rule `
5	express-detect-notevil-usage	routes/b2bOrder.ts:23	false_positive	0.95	The Semg
6	eval-detected	routes/captcha.ts:22	needs_review	0.75	The rule `
7	raw-html-format	routes/chatbot.ts:205	needs_review	0.85	The Semg
8	remote-property-injection	routes/currentUser.ts:31	true_positive	0.90	The code :
9	express-res-sendfile	routes/fileServer.ts:33	true_positive	0.95	The `file`
10	express-libxml-vm-noent	routes/fileUpload.ts:83	true_positive	0.99	The Semg
11	express-res-sendfile	routes/keyServer.ts:14	false_positive	0.90	The Semg

Per-finding details

#0 · detect-non-literal-regexp · lib/codingChallenges.ts:76 · verdict: needs_review

Verdict: needs_review

Confidence: 0.90

CWE confirmed: True

Reasoning

The `RegExp` constructor is used at line 76 to create a regular expression dynamically, incorporating the `challengeKey` variable. The rule `javascript.lang.security.audit.detect-non-literal-regexp.detect-non-literal-regexp` specifically targets this pattern, warning about potential Regular Expression Denial-of-Service (ReDoS) if `challengeKey` is an untrusted function argument. Without knowing the source or sanitization of `challengeKey`, it's not possible to confirm if it's truly attacker-controlled input. If `challengeKey` can be

manipulated by an attacker, they could craft a string that leads to catastrophic backtracking within the regex, blocking the main thread and causing a DoS.

Remediation

To determine exploitability, investigate the `challengeKey` variable: where it originates from and if it is subject to any input validation or sanitization before being used to construct the regular expression. If `challengeKey` is derived from user input, consider using a regex sanitization library or ensuring the regex pattern is safe from catastrophic backtracking. If `challengeKey` is not user-controlled, this finding can be suppressed.

Latency: 7.89s

- > #1 · detect-non-literal-regexp · lib/codingChallenges.ts:78 · verdict: needs_review
- > #2 · hardcoded-hmac-key · lib/insecurity.ts:44 · verdict: true_positive
- > #3 · hardcoded-jwt-secret · lib/insecurity.ts:56 · verdict: needs_review
- > #4 · hardcoded-hmac-key · lib/insecurity.ts:152 · verdict: needs_review
- > #5 · express-detect-notevil-usage · routes/b2bOrder.ts:23 · verdict: false_positive
- > #6 · eval-detected · routes/captcha.ts:22 · verdict: needs_review
- > #7 · raw-html-format · routes/chatbot.ts:205 · verdict: needs_review
- > #8 · remote-property-injection · routes/currentUser.ts:31 · verdict: true_positive
- > #9 · express-res-sendfile · routes/fileServer.ts:33 · verdict: true_positive
- > #10 · express-libxml-vm-noent · routes/fileUpload.ts:83 · verdict: true_positive
- > #11 · express-res-sendfile · routes/keyServer.ts:14 · verdict: false_positive
- > #12 · express-res-sendfile · routes/logfileServer.ts:14 · verdict: true_positive
- > #13 · express-sequelize-injection · routes/login.ts:34 · verdict: true_positive
- > #14 · express-res-sendfile · routes/quarantineServer.ts:14 · verdict: true_positive
- > #15 · express-open-redirect · routes/redirect.ts:19 · verdict: false_positive
- > #16 · express-sequelize-injection · routes/search.ts:23 · verdict: true_positive
- > #17 · eval-detected · routes/userProfile.ts:62 · verdict: needs_review
- > #18 · code-string-concat · routes/userProfile.ts:62 · verdict: needs_review
- > #19 · unknown-value-with-script-tag · routes/videoHandler.ts:58 · verdict: false_positive
- > #20 · unknown-value-with-script-tag · routes/videoHandler.ts:71 · verdict: needs_review
- > #21 · unsafe-formatstring · server.ts:155 · verdict: true_positive

> #22 · express-check-directory-listing · server.ts:269 · verdict: true_positive

> #23 · express-check-directory-listing · server.ts:273 · verdict: true_positive

> #24 · express-check-directory-listing · server.ts:277 · verdict: true_positive

> #25 · express-check-directory-listing · server.ts:281 · verdict: true_positive

Download results as JSON